ISO/IEC 27001:2022 Internal Audit Report

Audit period: 13 to 21 July 2026
Report prepared: Stage 7 GRC Advanced Assessment
Evidence marker: UBI-A7-598D6B60F230

Executive Summary

This report presents the results of an internal audit of Northstar Health's information security controls against twelve applicable Annex A control areas. The audit covered identity, endpoint, change, incident, supplier, backup, and logging processes supporting the patient-support SaaS production service.

Eighteen audit tests were executed across the twelve controls. All eighteen resulted in a nonconformity: three major, covering systemic, design, or recurrence issues, and fifteen minor.

Two of the three major findings are unresolved recurrences of findings from the prior year's audit that management had reported as closed.

Scope and Criteria

Entities in scope: identity platform, corporate endpoints, change process, incident process, critical suppliers, backups, and logging supporting the patient-support SaaS production service.

The twelve Annex A controls tested were:

A.5.15, A.5.16, A.5.18, A.5.19, A.5.24, A.5.30, A.6.3, A.8.5, A.8.8, A.8.13, A.8.15, and A.8.32.

The A.8.5 sample was expanded with two additional evidence requests covering the same excluded-account population identified in the identity export.

No fixed evidence-age threshold was specified in the assignment materials. Evidence currency was therefore assessed against the facts stated in the evidence pack. No additional evidence-age threshold was assumed.

Sampling Methodology and Known Limitation

Samples were selected deterministically from each population, including access, training, vulnerability, backup, and change populations, using a seed derived from the assigned evidence marker. This means the same marker can be used to reproduce the same sample IDs.

Excluded and duplicate population members, such as the duplicate access record ACC-004, were kept in the sample manifest with an explicit reason code rather than being silently removed.

Known limitation: The published sample sizes for each population, referred to as the "Audit sampling sheet" in the assignment's Environment Gate requirements, were not included in either the shared base pack or the private assignment overlay at the time of testing. This was escalated to programme support.

Therefore, A placeholder sample size of 99 was used. This was deliberately larger than any actual population and resulted in every eligible record in each population being included.

The placeholder was not presented as a published sample size.

Test Execution Summary

The audit-test-sheet.csv template supplied with the assignment contained twelve rows, one for each control.

However, the project brief, build sequence, FAQ, and related guidance separately stated that eighteen audit tests were required.

This was handled in the same way. Six controls were found to have a second, evidentially distinct operating-effectiveness fact in the evidence pack, separate from the fact used in the first test.

A second test was therefore created for each of those six controls. The six expanded controls and the reasoning behind each are documented in audit-engine/control_facts.py and the project decision log.

Test ID	Control	Result	Rule Applied	Nonconformity
AT-01	A.5.15	minor_nc	MINOR-OPERATING	NC-AT-01
AT-02	A.5.16	minor_nc	MINOR-OPERATING	NC-AT-02
AT-03	A.5.18	major_nc	MAJOR-SYSTEMIC	NC-AT-03
AT-04	A.5.19	major_nc	MAJOR-DESIGN	NC-AT-04
AT-05	A.5.24	minor_nc	MINOR-EVIDENCE	NC-AT-05
AT-06	A.5.30	major_nc	MAJOR-RECURRENCE	NC-AT-06
AT-07	A.6.3	minor_nc	MINOR-OPERATING	NC-AT-07
AT-08	A.8.5	major_nc	MAJOR-RECURRENCE	NC-AT-08
AT-09	A.8.8	minor_nc	MINOR-OPERATING	NC-AT-09
AT-10	A.8.13	major_nc	MAJOR-RECURRENCE	NC-AT-10
AT-11	A.8.15	minor_nc	MINOR-OPERATING	NC-AT-11

AT-12	A.8.32	minor_nc	MINOR-OPERATING	NC-AT-12
AT-13	A.5.24	minor_nc	MINOR-OPERATING	NC-AT-13
AT-14	A.6.3	minor_nc	MINOR-OPERATING	NC-AT-14
AT-15	A.8.8	minor_nc	MINOR-OPERATING	NC-AT-15
AT-16	A.8.32	minor_nc	MINOR-OPERATING	NC-AT-16
AT-17	A.8.15	minor_nc	MINOR-OPERATING	NC-AT-17
AT-18	A.5.19	minor_nc	MINOR-OPERATING	NC-AT-18

Prior Finding Retest

Three findings from the prior audit report dated 12 July 2025 were retested using objective closure evidence rather than relying only on management's closure claims.

Prior ID	Original Severity	Management Claim	Verified Status
NC-25-01	Major	Closed via new conditional-access policy	Open, recurrence. Two accounts still authenticate after their MFA exception expired.
NC-25-02	Minor	Closed via successful daily backups	Open, recurrence. No restore test has been performed since the 2025 database migration.
OBS-25-03	Observation	N/A	Closed, verified. All three suppliers now have a named owner.

For **NC-25-01**, management stated during the interview that the two affected accounts are non-human emergency identities and therefore do not fall within the scope of the original finding.

The audit found that these accounts still have access to privileged functions and authenticate without current, valid strong-authentication controls. On that basis, the root cause of the original finding remains present.

The disagreement is documented for management's response.

For **NC-25-02**, management stated that a consistently successful backup job constitutes a restore test.

The audit found that a successful backup demonstrates that data was written to the backup system. It does not demonstrate that the data can be restored, or that the restore process works against the current post-migration database version.

No restore has been demonstrated against the current production database.

Conclusion

All eighteen executed tests resulted in a nonconformity.

Three major nonconformities require priority remediation:

- **A.5.18:** access review scope and sign-off gaps
- **A.5.19:** missing supplier security assessment for HelpSphere
- **A.5.30 / A.8.13:** backup restore testing recurrence
- **A.8.5:** privileged multi-factor authentication recurrence

Full remediation ownership and status are recorded in nonconformity-register.csv and prior-findings-tracker.csv, which accompany this report.

This report should be read alongside audit-test-sheet.csv, evidence-verdicts.json, nonconformity-register.csv, and prior-findings-tracker.csv. These files contain the exact evidence locators supporting each conclusion.